



APPALACHIAN VALLEY MEDICAL CENTER

Incident Response Policy

AVMC Information Technology & Security

Policy Owner	AVMC Information Technology and Security
Applies To	All workforce members, contractors, students, vendors, systems, services, and authorized devices
Status	Approved/Final
Review Cycle	At least annually and following significant incidents, exercises, technology changes, or cybersecurity-risk changes

1. Purpose

The Appalachian Valley Medical Center (AVMC) Incident Response Policy establishes requirements for identifying, reporting, analyzing, containing, eradicating, recovering from, and learning from cybersecurity incidents.

AVMC depends on information systems to support patient care, clinical operations, medical devices, imaging and laboratory services, pharmacy operations, administration, physical security, building management, and communications. Cybersecurity incidents affecting these systems may disrupt patient care, compromise sensitive information, impair hospital operations, or create safety risks.

AVMC shall respond to cybersecurity incidents in a coordinated manner that prioritizes patient safety, preservation of critical services, protection of information, containment of threats, preservation of evidence, accurate communication, and timely recovery.

2. Scope

This policy applies to suspected or confirmed cybersecurity incidents involving AVMC-owned, managed, or authorized systems and information.

Covered resources include:

- clinical workstations and applications;
- the AVMC electronic health record;
- servers and infrastructure;
- administrative systems;

- imaging and laboratory systems;
- Medical IoT devices;
- Facilities/BMS and physical-security systems;
- network infrastructure and wireless networks;
- guest-network infrastructure;
- public-facing AVMC services;
- user accounts and credentials;
- organizational data;
- third-party services used by AVMC.

Examples of incidents include ransomware, malware, phishing, unauthorized access, credential compromise, data disclosure, network intrusion, loss or theft of devices, denial of service, and suspicious activity affecting AVMC operations.

3. Incident Reporting

All AVMC users shall promptly report suspected cybersecurity incidents to AVMC IT/Security.

Users shall report indicators including:

- ransomware messages or unexpected file extensions;
- inaccessible or unexpectedly modified files;
- suspicious email attachments or links;
- unexpected authentication prompts;
- malware or endpoint-security alerts;
- unauthorized account activity;
- suspected disclosure of sensitive information;
- unusual network or system behavior;
- lost or stolen AVMC devices.

Users shall not independently delete evidence, wipe systems, negotiate with attackers, pay ransom demands, or conduct unauthorized investigations.

Reports shall be triaged and validated to determine whether an incident has occurred and what level of response is required.

4. Incident Response Authority

AVMC IT/Security is responsible for coordinating the technical incident response.

When an incident is declared, AVMC shall designate an Incident Response Lead who coordinates containment, investigation, documentation, recovery, and technical communications.

Depending on the nature and severity of the incident, the response may also involve:

- executive leadership;
- clinical leadership;
- department managers;
- privacy/compliance personnel;
- legal counsel;
- communications/public-relations personnel;
- Facilities/BMS personnel;
- affected technology vendors or service providers;

- cyber-insurance representatives;
- law enforcement or government authorities when appropriate.

Only personnel specifically authorized by AVMC leadership may communicate externally on behalf of AVMC regarding an active cybersecurity incident.

5. Incident Prioritization

Incidents shall be evaluated according to their operational and cybersecurity impact.

Factors include:

- effects on patient safety or patient care;
- loss of availability of clinical services;
- number and criticality of affected systems;
- evidence of lateral movement;
- compromise of privileged accounts;
- involvement of sensitive or regulated information;
- effects on Medical IoT, Facilities/BMS, or physical-security systems;
- effects on backups or recovery systems;
- evidence of external data disclosure;
- likelihood that the incident remains active.

Incidents affecting patient care, critical clinical services, multiple network zones, backups, privileged infrastructure, or sensitive information shall receive immediate escalation.

NIST CSF 2.0 specifically calls for incident reports to be triaged and validated, incidents to be categorized and prioritized, and incidents to be escalated as needed.

6. Containment

AVMC shall contain cybersecurity incidents as quickly as reasonably possible while considering patient safety, operational continuity, and evidence preservation.

Authorized containment actions may include:

- disconnecting affected endpoints from the network;
- disabling compromised accounts;
- blocking malicious traffic;
- modifying ACLs or network security controls;
- isolating affected VLANs or network segments;
- disabling compromised wireless or switch ports;
- restricting communication between affected zones;
- suspending vulnerable services;
- isolating infected Medical IoT or Facilities/BMS devices when operationally safe;
- preventing compromised systems from communicating with backup infrastructure.

Network segmentation shall be used to limit lateral movement when possible.

For example, AVMC's existing separation of Guest, MED-IOT, Facilities/BMS, Clinical, Server, and management environments provides boundaries that may be used during containment.

Containment decisions affecting clinical technology shall be coordinated with appropriate clinical personnel when immediate disconnection could affect patient care.

7. Evidence Preservation and Investigation

AVMC shall preserve relevant evidence before destructive remediation whenever circumstances permit.

Evidence may include:

- system and application logs;
- authentication records;
- network logs;
- ACL and firewall records;
- suspicious email messages and attachments;
- malicious files;
- ransom notes;
- affected filenames and file extensions;
- timestamps;
- system configuration information;
- affected IP and MAC addresses;
- screenshots;
- relevant user reports;
- available volatile or forensic data.

Incident responders shall document significant investigative and response actions, including who performed the action, what was done, and when it occurred.

Evidence shall be protected from unauthorized alteration or destruction.

This directly supports CSF 2.0 RS.AN-06 and RS.AN-07, which address recording investigative actions and collecting incident data while preserving integrity and provenance.

8. Eradication

After adequate containment and investigation, AVMC shall remove the identified cause and artifacts of the incident.

Actions may include:

- removing malware;
- disabling compromised accounts;
- resetting affected credentials;
- removing unauthorized persistence;
- patching exploited vulnerabilities;
- correcting insecure configurations;
- rebuilding compromised systems;
- blocking identified malicious indicators;
- replacing compromised devices when necessary.

Responders shall consider whether an attacker retains access through additional systems, credentials, or persistence mechanisms before declaring eradication complete.

9. Recovery

AVMC shall restore affected services in a controlled and prioritized manner.

Recovery priorities shall consider patient safety and the operational importance of affected systems.

Before restoring a system to production, AVMC should verify that:

- the threat has been removed or adequately contained;
- required security controls are operating;
- restored systems are appropriately patched and configured;
- credentials have been reset when necessary;
- backups used for restoration are believed to be trustworthy;
- restored systems are monitored for recurrence.

Critical services should be restored before lower-priority systems when operational conditions require prioritization.

NIST recommends verifying the integrity of backups and other recovery assets before using them to resume operations.

10. Backup and Ransomware Response

AVMC shall maintain offline or otherwise logically isolated backups of critical systems and data sufficient to support recovery from ransomware, destructive malware, or other incidents that affect production availability or integrity. Backup repositories shall not rely on the same privileged credentials used to administer production systems.

Backup infrastructure shall use dedicated administrative or service credentials and least-privilege access controls. When an isolated backup repository requires network connectivity for a scheduled backup, integrity verification, restoration, or recovery test, connectivity shall be enabled only through an approved and documented access path limited to the necessary source, destination, protocol, and service. The repository shall be returned to its isolated state when the authorized activity is complete.

AVMC shall periodically verify backup integrity and test restoration procedures. Backup failures, unauthorized access, unexpected connectivity, or suspected credential compromise shall be escalated to AVMC IT/Security and addressed before the affected backup set is relied upon for recovery.

AVMC shall treat compromise of backup infrastructure as a significant escalation condition.

When ransomware is suspected:

- affected systems shall be isolated where operationally safe;
- further spread shall be investigated;
- backup systems shall be protected from affected systems;
- ransom notes and malicious artifacts shall be preserved;
- the suspected entry point shall be investigated;
- compromised credentials shall be identified and secured;
- the integrity of available backups shall be evaluated before restoration.

The discovery that backups are encrypted, unavailable, or otherwise compromised shall be immediately communicated to the Incident Response Lead and AVMC leadership because it materially changes recovery options.

No AVMC employee may independently negotiate or authorize ransom payment.

Any decision involving a ransom demand requires appropriate executive, legal, financial, insurance, and law-enforcement considerations according to organizational requirements.

11. Data Breach and External Disclosure

Evidence that AVMC information has been accessed, removed, or publicly disclosed shall trigger immediate escalation to leadership and appropriate privacy/legal personnel.

AVMC shall determine, to the extent reasonably possible:

- what information was affected;
- whose information was affected;
- whether information was accessed, exfiltrated, altered, or publicly disclosed;
- the likely scope of the exposure;
- applicable contractual, legal, regulatory, or notification obligations.

AVMC shall not speculate publicly about unverified facts.

External statements shall be coordinated through authorized leadership, legal/privacy personnel, and communications personnel.

12. Communications

Incident communications shall be accurate, timely, coordinated, and appropriate to the audience.

Employees shall receive instructions necessary to protect systems and continue operations safely.

Leadership shall receive information about incident scope, operational impact, containment, recovery status, material risks, and decisions requiring executive authority.

Patients, customers, partners, regulators, law enforcement, and the public shall receive information when appropriate and through authorized channels.

Personnel shall distinguish confirmed facts from information still under investigation.

NIST CSF 2.0 includes stakeholder notification and information sharing within RS.CO - Incident Response Reporting and Communication.

13. Post-Incident Review and Improvement

Following significant incidents and exercises, AVMC shall conduct a post-incident review or after-action process.

The review should identify:

- what occurred;
- how the incident was detected;
- what decisions were made;
- what worked;
- what failed or caused delay;
- whether network segmentation and other controls limited impact;
- whether communications were effective;
- whether recovery resources functioned as expected;
- changes needed to technology, policy, training, staffing, or procedures.

Improvement actions shall be assigned, prioritized, tracked, and incorporated into AVMC cybersecurity risk management activities as appropriate.

This reflects NIST SP 800-61 Rev. 3's model in which lessons learned feed continuous improvement across the CSF Functions.

14. Testing and Exercises

AVMC shall periodically test incident-response capabilities through tabletop exercises, technical testing, or other appropriate activities.

Exercises should include realistic scenarios affecting critical AVMC services and should evaluate:

- notification and escalation;
- containment decisions;
- evidence preservation;
- communications;
- recovery decisions;
- roles and responsibilities.

Lessons learned from exercises shall be used to improve this policy and related procedures.

15. Roles and Responsibilities

All users shall recognize and promptly report suspected incidents and follow instructions from authorized responders.

AVMC IT/Security shall triage reports, perform or coordinate technical investigation, implement authorized containment and eradication actions, preserve technical evidence, support recovery, and document response activities. IT/Security shall also maintain and validate the isolation, access controls, dedicated credentials, and recovery testing required for backup infrastructure.

Incident Response Lead shall coordinate response activities, maintain situational awareness, escalate material issues, and ensure significant decisions are documented.

Managers and clinical/system owners shall provide operational context, assist in determining system criticality, and support continuity and recovery decisions.

Privacy/legal personnel shall evaluate data-exposure and notification considerations.

Communications personnel shall coordinate authorized external messaging.

AVMC leadership shall provide executive direction and authorize significant organizational decisions outside the authority of technical responders.

16. NIST Cybersecurity Framework 2.0 Mapping

CSF 2.0 Area	AVMC Policy Alignment	Application
DE.CM - Continuous Monitoring	Supports detection of suspicious activity through system and network monitoring.	Sections 3, 7
RS.MA - Incident Management	Establishes declaration, triage, prioritization, escalation, and coordinated response.	Sections 3-5
RS.AN - Incident Analysis	Requires investigation, scope determination, documentation, and evidence preservation.	Sections 5, 7
RS.CO - Incident Response	Coordinates internal and	Sections 4, 11-12

Reporting and Communication	external incident communications.	
RS.MI - Incident Mitigation	Establishes containment and eradication requirements.	Sections 6, 8, 10
RC.RP - Incident Recovery Plan Execution	Establishes controlled restoration of affected systems and services.	Sections 9-10
ID.IM - Improvement	Uses incidents and exercises to identify and implement improvements.	Sections 13-14
GV.RR - Roles, Responsibilities, and Authorities	Defines incident-response responsibilities and decision authority.	Sections 4, 15

NIST CSF 2.0 specifically describes Respond as actions taken regarding detected incidents and Recover as restoration of affected assets and operations.

References

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29.

Nelson, A., Rekhi, S., Scarfone, K., & Souppaya, M. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. NIST SP 800-61 Rev. 3.

CISA. Tabletop Exercise Packages.

SANS Institute. Security Policy Templates.